TrustForge™

Comprehensive System Documentation & Technical Architecture Guide

Product Version:	`v1.0.0-release (Production Golden Master)`
Regulatory Scope:	`Digital Personal Data Protection Act 2023 (India)`
System Architecture:	`React 18 + Express.js API + Python 3.12 RAG`
Authentication:	`PBKDF2 (SHA-512, 10k iter) + HMAC-SHA256 Tokens`
Compliance Scoring:	`6-Pillar Deterministic Trust Score + TOPSIS MCDM`

Executive Overview: This document constitutes the definitive technical system documentation for the TrustForge compliance auditing and model benchmarking platform. It provides detailed architectural, operational, algorithmic, and mathematical specifications for the complete 14-step assessment pipeline, the 6-pillar Trust Score formulation, hybrid dense/sparse information retrieval, the 10-model evaluation matrix, and platform administrative governance controls.

Section 1: Product Purpose & Architecture Overview

TrustForge is an automated compliance auditing, risk assessment, and decision-support platform designed to evaluate enterprise data processing practices against India's Digital Personal Data Protection (DPDP) Act 2023 (Act No. 22 of 2023). The platform addresses the operational gap enterprises face when translating complex statutory mandates into technical specifications, verifiable evidence collections, and objective compliance scores.

- The system is organized into a modular, multi-tier architecture consisting of:
- Client Frontend: A responsive Single Page Application built with React 18, TypeScript, Tailwind CSS, and Lucide Icons.
- Application API Gateway: A robust Express.js REST API providing multi-tenant routing, authentication, and persistence.
- Compliance & RAG Engine: A Python 3.12 service executing hybrid lexical (BM25) and dense vector retrieval, statutory citation extraction, and model benchmarking.
- Multi-Tenant Storage Layer: A durable, ACID-compliant persistence store with strict foreign-key tenant isolation and SHA-256 evidence vaults.

Section 2: Customer-Facing Features & Compliance Tools

- TrustForge provides compliance teams and Data Protection Officers (DPOs) with an integrated compliance workspace:
- Public & Authenticated Perimeter Scanner: Non-invasive crawl of corporate domains to audit cookie consent notices, tracker scripts, SSL/TLS ciphers, and security headers.
- -Step Statutory Assessment Wizard: Comprehensive questionnaire evaluating corporate privacy controls against specific DPDP Act sections.
- Compliance Findings Vault: Centralized defect tracker linking identified vulnerabilities to violated statutory provisions and potential statutory penalty exposure.
- Cryptographic Evidence Locker: Secure repository for policies, architectural schemas, and audit logs, hashed with SHA-256 upon ingestion for tamper evidence.
- Interactive Remediation Roadmap: Prioritized task management engine projecting Trust Score improvements upon completing corrective actions.
- Statutory Report Generation: One-click export of structured executive summaries, auditor finding reports, and machine-readable JSON disclosures.
- Citizen Data Principal Rights Portal: Request tracking dashboard managing Access, Correction, Erasure, and Grievance workflows with 30-day statutory SLA countdowns.

Section 3: Administrative Governance & Platform Console

- Platform administrators access a dedicated, server-verified administrative command center strictly isolated from standard customer accounts:
- Isolated Authentication Gate: Dedicated /admin/login endpoint verifying the platform_admin role on the server before granting console access.
- Platform Command Center: Global telemetry aggregating cross-tenant compliance indices, background scanner queues, and active audit jobs.
- Multi-Tenant Organization Governance: Management portal for inspecting tenant subscription tiers, domain verification records, and Significant Data Fiduciary (SDF) classifications.
- Enterprise User Directory & Access Control: Directory controls for provisioning accounts, managing role-based access control (RBAC), and revoking active user sessions.
- Scan Dispatcher Queue: Real-time telemetry monitoring crawler worker concurrency, job latency percentiles, and automatic retry queues.
- Global Defect & Finding Registry: Cross-organization vulnerability tracker categorizing statutory non-compliance items by severity.
- Statutory Rules Engine: Configuration matrix allowing authorized legal engineers to tune compliance weights, penalty multipliers, and section thresholds.
- Immutable Security Audit Trail: Append-only forensic ledger recording actor IP, timestamp, action performed, and response codes for every administrative operation.

Section 4: Technology Stack & Integration Topology

- TrustForge leverages modern, open, and robust software engineering standards:
- Frontend: React 18, TypeScript 5, Vite, Tailwind CSS 3, Lucide React, Playwright E2E automation.
- Backend API: Node.js 22 LTS, Express.js 4, TypeScript, Native crypto module (PBKDF2, HMAC-SHA256).
- Compliance & AI Service: Python 3.12, PyTest, NumPy, AsyncIO, PyDantic, Scikit-Learn.
- Information Retrieval: Dense semantic embeddings, BM25 sparse keyword index, Reciprocal Rank Fusion (k=60).
- Storage & Persistence: Durable SQLite storage engine with foreign-key isolation, Supabase PostgreSQL client integration, local file vault.
- Security & CI: GitHub Actions CI with automated Node/Python testing, secret scanning, and branch protection.

Section 5: Data Model, Authentication & Multi-Tenant Isolation

- Data security and tenant isolation are enforced across all layers of the TrustForge architecture:
- Password Security: Passwords are never stored in plaintext. TrustForge derives hashes using standard PBKDF2 (SHA-512, 10,000 iterations) with a 16-byte cryptographically secure random salt generated per user via crypto.randomBytes(16).
- Session Authentication: Sessions are managed via HMAC-SHA256 signed tokens formatted as tf_tok_${payload}.${signature}. Payloads encode user ID, tenant organization ID, assigned role, issued-at timestamp, and 24-hour expiration TTL.
- Multi-Tenant Isolation: Every database query in customer routes enforces an org_id foreign-key filter extracted from the verified session token. Cross-tenant access attempts are rejected and logged.
- Storage Isolation: Uploaded evidence documents are stored in tenant-specific directories partitioned by organization ID.

Section 6: DPDP Legal Corpus & Statutory Grounding Architecture

- TrustForge roots all compliance assessments in the official statutory text of the Digital Personal Data Protection Act 2023 (Act No. 22 of 2023):
- Corpus Ingestion: The complete gazetted text comprising 44 sections across 9 chapters and 2 schedules is parsed, cleaned, and chunked into canonical statutory units.
- Canonical Control Mapping: The platform defines 20 canonical controls mapped from the faculty C1–C10 compliance taxonomy, covering Notice (§5), Consent (§6), Purpose Limitation (§4, §7), Storage Limitation (§8(7)), Technical Safeguards (§8(5)), Breach Notification (§8(6)), Minor Data Safeguards (§9), SDF Obligations (§10), Principal Rights (§11-14), and Grievance Redressal (§13).
- Deterministic Grounding Validator: When evaluating compliance statements, the system verifies that statutory citations exist in the gazetted legal schema. Citations that fail section boundary or similarity checks are rejected to prevent hallucinated compliance claims.

Section 7: Automated Website Perimeter Security & Scanner

- The perimeter security scanner audits internet-facing corporate web properties without requiring invasive agents or code injection:
- Cookie Banner Analysis: Inspects web pages for affirmative cookie consent dialogs, pre-checked opt-in inputs (prohibited under §6(1)), and accessible policy links.
- Privacy Notice Verification: Scans for public links to statutory privacy policies and verifies accessibility.
- Transport Layer Security (TLS): Validates active HTTPS enforcement, SSL certificate expiration, and modern TLS cipher negotiation.
- Defensive HTTP Headers: Checks for security response headers including HTTP Strict Transport Security (HSTS), Content-Security-Policy (CSP), and X-Frame-Options.
- Third-Party Trackers: Detects external tracking and analytics scripts operating on web assets to identify unconsented data sharing.

Section 8: 14-Step Statutory Assessment Workflow

- The core audit workflow guides assessors through 14 modular control sections corresponding to the DPDP Act 2023:
- Step 1 — Governance Architecture (§8(1), §10(2)(a)): DPO appointment, compliance reporting lines, and accountability.
- Step 2 — Consent Validation (§6(1)): Unbundled, affirmative, freely given, and specific consent mechanisms.
- Step 3 — Multilingual Notice (§5): Plain language notice available in English and 22 Indian Eighth Schedule languages.
- Step 4 — Consent Manager Readiness (§6(7)-(9)): Technical capability to interface with registered Consent Managers.
- Step 5 — Purpose Limitation & Minimization (§4, §7): Prohibition of collateral data harvesting.
- Step 6 — Storage Limitation & Secure Erasure (§8(7)): Automated retention schedules and secure data shredding.
- Step 7 — Data Quality & Accuracy (§8(3)): Integrity of data used in decision-making affecting data principals.
- Step 8 — Security Safeguards (§8(5)): Role-based access control, cryptographic protection, and vulnerability management.
- Step 9 — Personal Data Breach Management (§8(6)): Incident response procedures and DPB notification readiness.
- Step 10 — Minor Data & Guardianship (§9): Parental consent verification and prohibition of tracking/targeted ads.
- Step 11 — Data Principal Rights (§11-14): Self-service access, correction, erasure, and nomination procedures.
- Step 12 — Grievance Redressal (§13): DPO grievance officer designation and statutory response timelines.
- Step 13 — Significant Data Fiduciary Mandates (§10): DPIA frameworks, independent audit readiness, algorithmic risk reviews.
- Step 14 — Review & Synthesis Matrix: Pre-submission verification matrix consolidating all answers and attached evidence.
- Evaluation Output: Generates detailed compliance percentage ratings, statutory gap listings, and remedial action roadmaps.

Section 9: Six-Pillar Trust Score Engine & Gating Formulations

- The TrustForge Trust Score is a deterministic, normalized index in [0, 100] computed across six statutory pillars:
- Privacy Architecture (Weight: 0.20) — Notice itemisation, affirmative consent, withdrawal accessibility, purpose limitation.
- Security Safeguards (Weight: 0.20) — TLS/HTTPS transport, defensive security headers, breach management, tracker controls.
- Transparency & Notice (Weight: 0.15) — DPO contact accessibility, third-party sharing disclosures.
- Governance & Accountability (Weight: 0.15) — Processor contracts, children's data safeguards, compliance recordkeeping.
- Data Lifecycle Management (Weight: 0.15) — Data retention cessation, erasure workflows, minimisation.
- Data Principal Rights (Weight: 0.15) — Right to access summary, correction/updating, grievance redressal.
- Sum of weights equals exactly 1.00.
- Gating Caps & Posture Bands:
- Critical Failure Gating: If the perimeter scanner detects that HTTPS is missing or a statutory privacy notice is absent, the Trust Score is deterministically capped at min(TS, 40), enforcing a Low posture rating regardless of self-assessment responses.
- Posture Classifications: Low (0–39), Moderate (40–59), Good (60–79), Strong (80–100), and NOT_SCORABLE.
- Weighting Schemes Supported: Both W1 (Penalty-Proportional based on statutory fine ceilings) and W2 (Equal category weighting).

Section 10: Hybrid Dense/Sparse Information Retrieval & RRF

- To retrieve statutory legal excerpts accurately without lexical bias or semantic drift, TrustForge implements hybrid retrieval:
- Lexical Sparse Search: An in-memory BM25 index indexing canonical DPDP Act sections and evidence chunks, matching exact legal terminology and section identifiers.
- Dense Vector Search: High-dimensional semantic embeddings capturing conceptual legal meanings and statutory requirements.
- Reciprocal Rank Fusion (RRF): Results from lexical and vector retrieval are fused using standard RRF:
- RRF_Score(d) = sum_{m in {dense, sparse}} 1 / (k + rank_m(d))
- where k = 60 is the smoothing constant preventing high-ranking outliers from dominating fusion.
- Verification: The Live RAG Monitor (/rag-monitor) provides real-time visibility into retrieval ranks, cosine similarities, and retrieved text boundaries.

Section 11: Designated Model Slots & Zero-Paid-Inference Policy

- TrustForge defines 10 standardized candidate model slots (M01–M10) for benchmarking automated compliance reasoning:
- M01: OpenAI GPT-OSS 120B (Groq LPU free tier)
- M02: OpenAI GPT-OSS 20B (Groq LPU free tier)
- M03: Qwen3.8-27B (Groq LPU free tier)
- M04: Gemma 4 31B (OpenRouter google/gemma-4-31b-it:free)
- M05: Gemma 4 26B-A4B (OpenRouter google/gemma-4-26b-a4b-it:free)
- M06: Llama 3.3 70B (Commercial tier — gated)
- M07: Mistral Small 24B (Commercial tier — gated)
- M08: DeepSeek V4.1 Flash (Commercial platform — gated)
- M09: Sarvam 105B (Commercial platform — gated)
- M10: Sarvam 30B (Local weights / Ollama slot)

Strict Zero-Paid Inference Enforcement: To eliminate recurring operational costs and prevent enterprise privacy data from being transmitted to paid third-party APIs without explicit consent, TrustForge strictly blocks billable models M06–M09 by default. Commercial API calls are gated with zero financial spend ($0.000000).

Section 12: Benchmark Methodology & TOPSIS Multi-Criteria Decision Analysis

- To evaluate candidate language models objectively, TrustForge implements the Technique for Order of Preference by Similarity to Ideal Solution (TOPSIS):
- Evaluation Criteria (7 Primary Criteria):
- Macro-F1 Score (Benefit, Weight: 0.30): Macro-averaged classification accuracy against ground truth.
- Statutory Citation Precision (Benefit, Weight: 0.15): Percentage of citations accurately matching DPDP Act provisions.
- Evidence Faithfulness (Benefit, Weight: 0.15): Alignment of extracted quotations against submitted evidence.
- Inter-Run Consistency (Benefit, Weight: 0.10): Repeatability across identical evaluations.
- Median Turnaround Latency (Cost, Weight: 0.10): Execution time per canonical evaluation.
- Cost per Assessment in INR (Cost, Weight: 0.10): Direct API cost per complete assessment.
- Deployment Feasibility (Benefit, Weight: 0.10): Practicality considering rate limits and data sovereignty.
- Mathematical Formulation:
- Vector Normalization: r_ij = x_ij / sqrt(sum_k x_kj^2)
- Weighted Matrix: v_ij = w_j * r_ij
- Ideal Solutions (A+ and A-)
- Euclidean Distances (D+ and D-)
- Relative Closeness: C_i = D_i^- / (D_i^+ + D_i^-), C_i in [0, 1]
- Empirical Results: Open, locally executable and free-tier models attain top recommendations under sovereign and cost-constrained operational profiles.

Section 13: Evidence Management, Auditing & Report Generation

- TrustForge manages compliance evidence with strict chain-of-custody controls:
- Ingestion Hashing: Every uploaded file (PDF, DOCX, PNG, CSV) is hashed using SHA-256 upon reception. The resulting digest is stored immutably to ensure files are tamper-evident.
- Evidence Indexing: Uploaded text content is indexed into the RAG vector store for retrieval during compliance assessments.
- Report Export Suite: Compliance teams can export executive reports in PDF and JSON formats. Reports aggregate pillar scores, section ratings, legal citations, and open remediation roadmaps for internal stakeholders and auditor reviews.
- Security Audit Ledger: An append-only audit log records login attempts, role demotions, profile changes, and report downloads with UTC timestamps and IP addresses.

Section 14: Security Protections, Access Controls & Known Limitations

- Security Architecture & Threat Mitigation:
- Credential Protection: Standard PBKDF2 password derivation (SHA-512, 10,000 iterations) with 16-byte random salt.
- Session Security: HMAC-SHA256 signed session tokens with 24-hour expiration and constant-time signature verification.
- Input Sanitization: SQL injection prevention via parameterized queries and durable ORM stores.
- Role-Based Access Control (RBAC): Dedicated roles (Owner, Admin, Compliance Officer, Auditor, Viewer, Super Admin) with server-side route guards.
- Operational & Environmental Limitations:
- Self-Assessment Subjectivity: Assessment questionnaire responses reflect organizational self-reporting; scores should be verified against uploaded evidence documents.
- DNS Propagation: Automated DNS domain ownership verification relies on public DNS propagation delays.
- Zero-Paid Inference Boundary: Commercial LLMs (M06–M09) are gated by default to prevent unauthorized inference charges.

Section 15: Installation, Execution & Testing Summary

- System Requirements & Verification:
- Prerequisites: Node.js 22 LTS or later, Python 3.12 or later, Git, Google Chrome / Chromium.
- Local Installation:
- git clone https://github.com/Mannan55/TrustForge.git
- cd TrustForge
- npm --prefix api install && npm --prefix api run build
- npm --prefix "TrustForge Frontend" install
- pip install -r backend/requirements.txt
- Service Startup:
- API: node api/dist/index.js (Runs on http://127.0.0.1:8000)
- Frontend: npx --prefix "TrustForge Frontend" vite (Runs on http://127.0.0.1:5173)
- Automated Regression Suite:
- python -m pytest backend (29 tests passing)
- npm --prefix api test (180 tests passing)

Section 16: Technical Design Decisions & Future Enhancements

- Architectural Decisions & Future Roadmap:
- Air-Gapped & Local-First Philosophy: Designed to operate entirely on local infrastructure or private enterprise clouds, ensuring sensitive personal data is not leaked to external third-party APIs.
- Standardized 6-Pillar Model: Structured around 6 pillars mapping from the faculty C1–C10 compliance taxonomy to provide balanced coverage across governance, technical security, and citizen rights.
- Future Enhancements:
- Dynamic integration with official Data Protection Board Consent Manager APIs as subordinate rules are notified.
- Automated crawler extensions for native mobile application privacy policy and tracker inspection.
- Integration with enterprise identity providers (SAML 2.0 / OpenID Connect) for unified enterprise single sign-on (SSO).